

MY CYBER ACADEMY

Unit U01

CREST Practitioner Intrusion Analyst (CPIA)

# Course Introduction & Soft Skills / Incident Handling

The analyst mindset, the IR lifecycle, and the law and threat models that frame every engagement.

GROUP A | SOFT SKILLS | INCIDENT HANDLING

© Billy Forrest

# Fourteen units, six knowledge groups, one certification

| Knowledge Group | Focus | units |
|---|---|---|
| A · Soft Skills & Incident Handling | Engagement, chronology, law, threat | 1 |
| B · Core Technical Skills | Protocols, tools, fingerprinting, crypto, host analysis | 2–4 |
| C · Background Info Gathering & OSINT | WHOIS, DNS, open-source investigation | 5 |
| D · Network Intrusion Analysis | Capture, logs, C2, exfiltration, attacks | 6–8 |
| E · Analysing Host Intrusions | Acquisition, Windows FS, registry, memory, malware | 9–11 |
| F · Reverse Engineering Malware | Anti-RE, PE format, obfuscation, behaviour | 12–14 |



© Billy Forrest

UNIT OBJECTIVES

# By the end of this unit you will be able to

- **Describe the CPIA exam** its six knowledge groups and how this course maps to them
- **Explain the analyst role** the traits and experience that make a good analyst, and the impact of bias
- **State the IR lifecycle** suspect, acquire, analyse, report, deploy countermeasures
- **Explain the cyber kill chain** the seven phases of a targeted intrusion
- **Apply law and compliance** to incident handling and evidence
- **Use the TAME model** and risk treatment options in threat assessment


© Billy Forrest

# What makes a good analyst?

- **Flexibility** adapt to changing circumstances
- **Logical and independent mind** question assumptions and reason clearly
- **Attention to detail** the small clues carry the investigation
- **Objectivity and sensitivity** handle confidential information with care
- **Concentration and patience** long analysis units, careful work
- **Confidence in your own judgement** defensible conclusions



© Billy Forrest

# Where analyst skills come from

| Background | Transferable skill |
|---|---|
| IT / troubleshooting | Diagnosing problems methodically |
| Networking | Setup, configuration and protocol awareness |
| IT hardware | Storage identification, component handling |
| Software engineering | Low-level computing, scripting |
| Law enforcement | Continuity, direction, human evidence sources |



© Billy Forrest

# Analyst bias

- **Conscious and unconscious bias** built through upbringing, culture, education and occupation
- **Cognitive bias** systematic errors in thinking that distort judgement
- **Forensic confirmation bias** pre-existing beliefs and motives shape how evidence is gathered
- **The risk** prejudicial information — ethnicity, criminal record — compromises impartiality
- **The guard** recognise and actively counter bias in your analysis



© Billy Forrest

DISCUSSION

# Why must an analyst actively guard against confirmation bias?

Think of a case where you already believe you know who the intruder is. How does that belief change what you look for, and what you dismiss?

Confirmation bias can steer an entire investigation toward a premature conclusion.


© Billy Forrest

# Benefits and utility of incident response

- **A framework for incidents** reduces errors and prevents loss of critical forensic data
- **A clear path to the cause** establishes how the incident happened
- **Legal and stakeholder notification** all parties informed when required
- **Reduced reputational damage** effective management of the incident
- **Rapid, systematic recovery** business impact kept to a minimum


© Billy Forrest

# Preparation before an incident

- **Establish an IR team** roles and responsibilities agreed in advance
- **Conduct threat analysis** know the likely threat actors
- **Outline response guidelines** and procedures for external communication
- **Communicate with personnel** and understand the relevant policies
- **Train employees** and test the IR plan
- **Capture lessons learned** improve the plan after every exercise


© Billy Forrest

# The IR lifecycle

1. **Suspect a compromise**
   human or machine detection of an anomaly
2. **Acquire data**
   memory dumps, packet captures, logs, disk images
3. **Analyse data**
   correlate and reconstruct the timeline
4. **Report**
   a forensic, structured summary of the compromise
5. **Deploy countermeasures**
   prevent recurrence and harden the posture



© Billy Forrest

# The cyber kill chain

1. **Reconnaissance**
   research, identify and select targets
2. **Weaponisation**
   pair remote-access malware with an exploit into a deliverable
3. **Delivery**
   transmit the weapon to the target
4. **Exploitation**
   the weapon executes and runs code
5. **Installation**
   a backdoor is installed for persistence
6. **Command and control**
   the code connects back for instructions
7. **Actions on objective**
   the attacker pursues their aims



© Billy Forrest

QUIZ

# Activity: map the kill chain

- A user opens a PDF that drops a backdoor — which kill chain phase?
- The malware phones home for instructions — which phase?
- The attacker pivots to steal data — which phase?
- A spear-phishing email is crafted for a named victim — which phase?
- Order the seven phases for a ransomware intrusion.

Recon → Weaponise → Deliver → Exploit → Install → C2 → Act on objective.


© Billy Forrest

# Incident chronology

- **Reconstruct the timeline** order events from all evidence sources
- **Correlate sources** network logs, host logs, captures, memory
- **Establish a chain of events** what happened, when, and in what order
- **Feed the bigger picture** cross-reference with historical reports
- **Enable management metrics** and shared threat intelligence



© Billy Forrest

# Law, compliance and evidence

- **Engagement lifecycle** scope, legality and record-keeping
- **Applicable legislation** Computer Misuse Act, Data Protection Act, GDPR
- **Evidence integrity** do not change data; preserve the audit trail
- **Independent review** a third party should reproduce your result
- **Confidentiality** sensitive data handled appropriately


© Billy Forrest

# Risk ownership and the TAME model

- **Risk ownership** each risk is owned by a named stakeholder
- **Documentation** supports ISO 27001, ISO 9001 and other certifications
- **TAME model** Threat Assessment Model for Electronic payment systems
- **Four stages** assessment scope; threat agent & vulnerability analysis; scenario construction & system modelling; evaluation
- **Scalable** built for payment systems, extensible to enterprise networks



© Billy Forrest

# STRIDE: what it is and how to use it

- **Origin** Microsoft, 1999, Kohnfelder and Garg, for threat modelling software designs
- **Method** walk the design, name the threats one class at a time, then agree the control
- **Six classes** spoofing, tampering, repudiation, information disclosure, denial of service, elevation of privilege
- **Output** a threat per row, a control per threat, and one named owner who accepts the residual risk
- **Limit** it names threats, it does not score them, so pair it with likelihood and impact


© Billy Forrest

# STRIDE for the risk owner

| STRIDE | Threat class | The owner asks |
|---|---|---|
| S | Spoofing | Can someone claim another identity in our logs? |
| T | Tampering | Can evidence be altered before the report? |
| R | Repudiation | Can a party deny the action, and do we hold proof? |
| I | Information disclosure | Who can read the data, at rest and in transit? |
| D | Denial of service | What stops the investigation at the worst moment? |
| E | Elevation of privilege | Can a low privilege account reach the evidence? |



© Billy Forrest

# Risk treatment options

| Option | Meaning | Example |
|---|---|---|
| Acceptance | No action necessary | Low-risk, low-impact residual risk |
| Avoidance | Risk is no longer present | Stop the activity entirely |
| Reduction | Risk is less of a threat | Add controls to lower likelihood |
| Transference | Risk is someone else's problem | Insurance, outsourcing |


© Billy Forrest

# Attribution: state vs non-state attackers

| Attacker | Characteristics |
|---|---|
| State | Government / military / intelligence; very sophisticated; large budget; long-running campaigns; target national infrastructure |
| Non-state | Individuals / organised groups / terrorists; lower sophistication; small or no budget; often profit or thrill driven |



© Billy Forrest

# Group A at a glance

| Ref | Topic | Core idea |
|---|---|---|
| A1 | Engagement lifecycle management | Prepare, detect, acquire, analyse, report, countermeasure |
| A2 | Incident chronology | Reconstruct and correlate the timeline |
| A3 | Law & compliance | Legal framework, evidence integrity, confidentiality |
| A5 | Threat assessment | TAME model, risk ownership, risk treatment |



© Billy Forrest

## KEY TAKEAWAYS

- **The analyst role** demands objectivity, attention to detail and active bias management
- **IR is a lifecycle** suspect → acquire → analyse → report → countermeasure
- **The kill chain** seven phases — recon to actions on objective
- **Law frames the work** evidence integrity, confidentiality and legality
- **Threats are assessed** with the TAME model and explicit risk treatment


© Billy Forrest

QUIZ

# confirmation quiz (Group A)

- Which IR phase collects memory dumps and packet captures?
- What is the key difference between a state and a non-state attacker?
- Risk transference means the risk is:
- Which kill chain phase follows 'installation'?
- Why does confirmation bias threaten an investigation?

Answers in the confirmation quiz — aim for 60 percent before leaving.


© Billy Forrest

NEXT SESSION

# Next unit: Core Technical Skills I

- IPv4 and IPv6 addressing, TCP, UDP and ICMP
- Application-layer protocols: HTTP(S), SMTP, DNS, FTP, SMB, SNMP
- The OSI model and how the web and email work
- Network architectures and common tool classes

Reading: Knowledge Group B source material.


© Billy Forrest